NOVAGEN DEFENSE

Incident & Defense Report

Security Assessment of a ColddBox WordPress Web Portal

Enterprise / Lab	Novagen Defense
Target	ColddBox
Platform	TryHackMe
Student / Analyst	Tanmay Janghel
Assessment Date	5 October 2026

CONFIDENTIAL — EDUCATIONAL / AUTHORIZED LAB USE

1. Executive Summary

This assessment evaluated the security of the ColddBox WordPress web portal in an authorized TryHackMe laboratory environment. The supplied evidence shows an attack path from reconnaissance to WordPress credential access, authenticated server-side code execution, shell access as the web-service account, and privilege escalation to effective root privileges.

The key risk is the combination of weak authentication controls, administrative ability to edit executable PHP theme files, and an unsafe SUID configuration. Together these weaknesses allowed the compromise to progress from a web application account to root-level control of the host.

Priority remediation is to enforce MFA and strong unique credentials, rate-limit WordPress authentication, disable web-based theme/plugin code editing, remove unnecessary SUID permissions, apply least privilege to service accounts, and alert on suspicious authentication, file modification, and process activity.

Assessment Scope & Limitations

Scope: 10.48.145.166 / ColddBox WordPress application and the associated Linux host, based on the supplied evidence. The screenshots represent a controlled educational lab; no claim is made about systems outside the target.

Risk Summary

Finding	Impact	Priority
Weak WordPress authentication	Unauthorized administrative access	High
Theme Editor permits PHP execution	Web-server compromise	Critical
SUID find permits privilege escalation	Root-level host compromise	Critical
Limited defensive controls	Attack chain can proceed with reduced resistance	High

2. Cyber Kill Chain Mapping

Phase	Observed activity	Evidence
Reconnaissance	Interface information and Nmap service detection; HTTP/Apache identified on 10.48.145.166.	Figs. 1–2
Discovery	Gobuster found /hidden/, /wp-admin/, /wp-content/, /wp-includes/ and related paths.	Fig. 3
Credential Access	WPScan recovered the c0ldd WordPress account; password redacted.	Figs. 4–5
Exploitation	Authenticated Theme Editor used to insert PHP reverse-shell code.	Figs. 6–8
Command & Control	Netcat received a connection; shell ran as www-data.	Fig. 9
Privilege Escalation	SUID /usr/bin/find used to obtain euid=0(root).	Figs. 10–12
Actions on Objectives	/root and root.txt were accessed in the lab.	Figs. 13–15

3. Technical Findings & Evidence

3.1 Network Reconnaissance

The ifconfig evidence shows the Kali assessment interface at 192.168.142.133/24 and a tunnel interface at 192.168.181.160/18. Nmap targeted 10.48.145.166 and identified TCP/80 as open with Apache httpd 2.4.18 on Ubuntu.

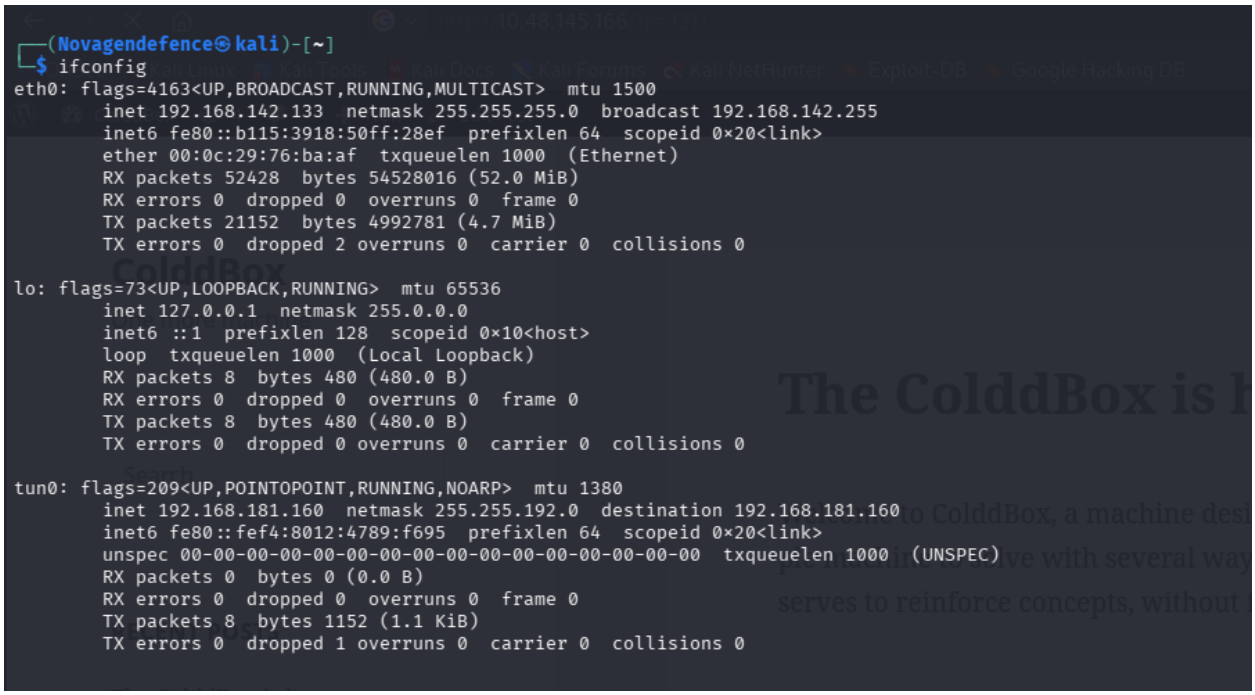


Figure 1. Assessment host interface information (ifconfig).

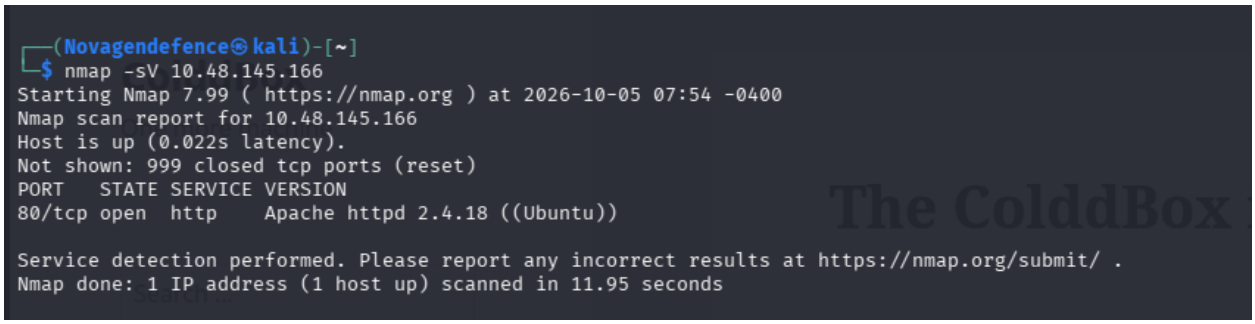


Figure 2. Nmap service/version detection against 10.48.145.166.

3.2 Web Content Discovery

Gobuster identified WordPress administration and content paths including /wp-admin/, /wp-content/, /wp-includes/ and /hidden/. This provided a clear route into the WordPress application.

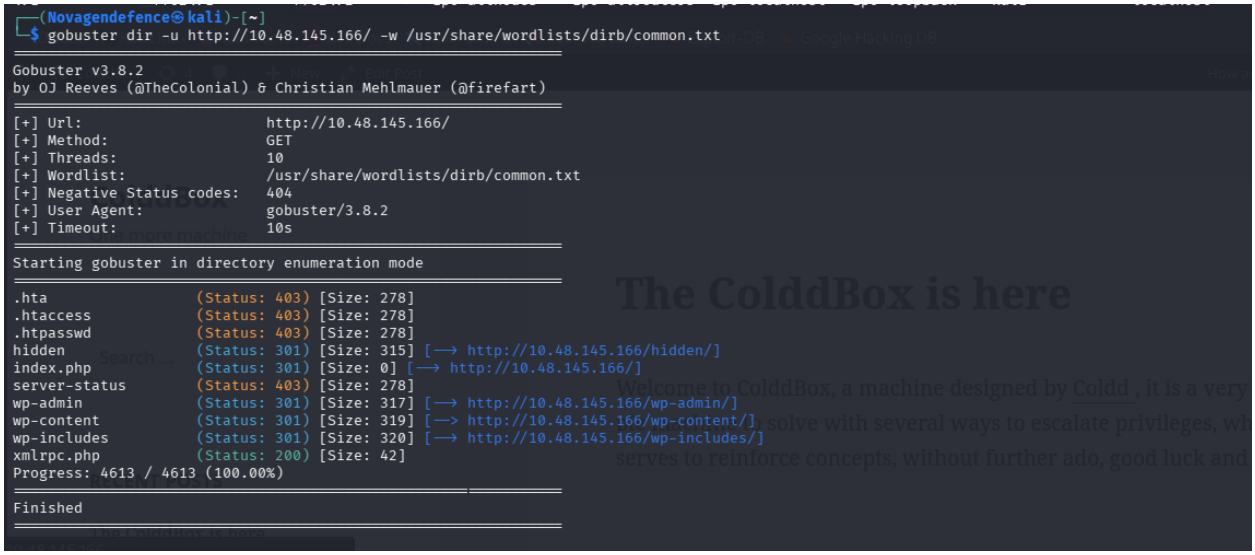


Figure 3. Gobuster directory enumeration results.

3.3 WordPress Authentication Attack

WPScan was used against wp-login.php with the supplied c0ldd username and a password wordlist. The tool reported a successful credential combination. The password is redacted from the report narrative.

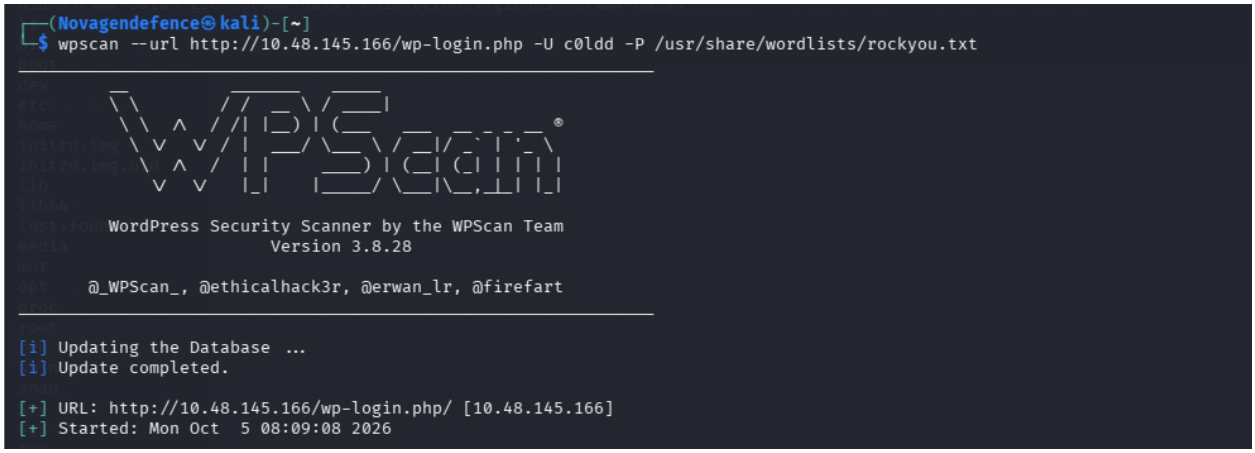


Figure 4. WPScan authentication attack initiated.



Figure 5. Successful c0ldd credential result; password redacted.

3.4 Theme Editor / PHP Web Shell

The WordPress Theme Editor was accessible after authentication. The evidence shows PHP reverse-shell code inserted into a Twenty Fifteen template with callback address 192.168.181.160:1234. The implementation references the public pentestmonkey PHP reverse-shell project.

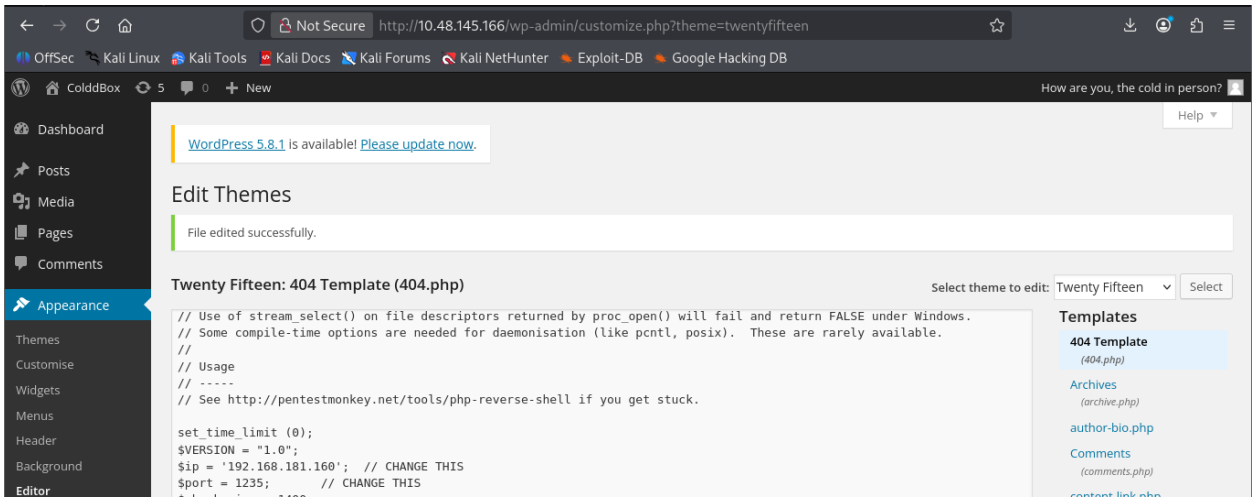


Figure 6. WordPress Theme Editor showing modified PHP template code.

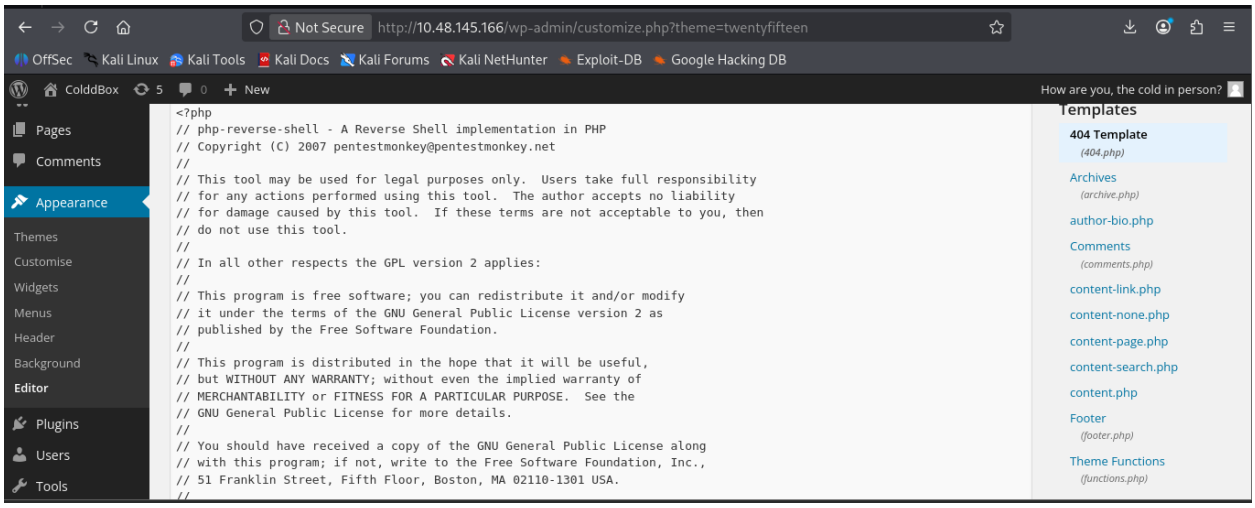


Figure 7. Theme Editor showing the PHP reverse-shell implementation.

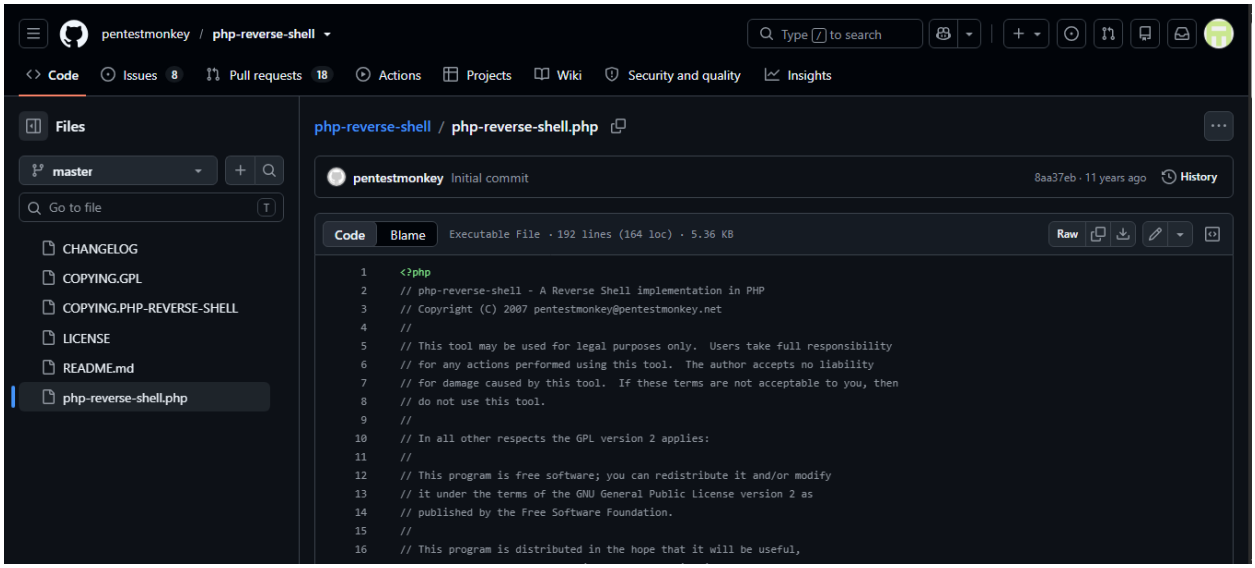


Figure 8. Public source repository used as reference.

3.5 Shell Establishment

The listener received a connection from 10.48.145.166. The shell reported uid=33(www-data), confirming command execution under the web-server account.

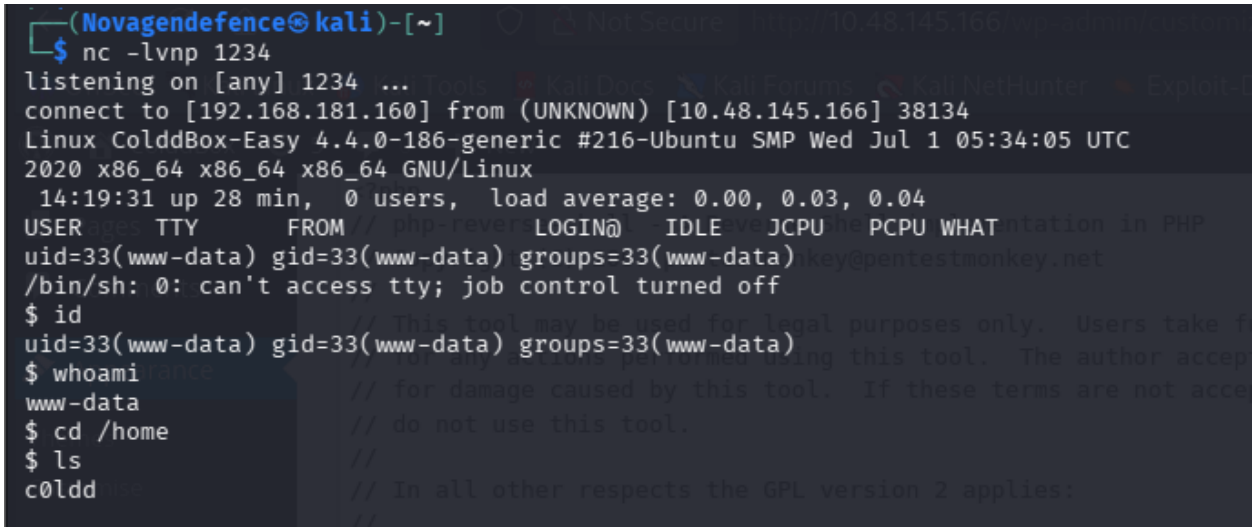


Figure 9. Incoming shell connection and www-data execution context.

3.6 Privilege Escalation via SUID find

A SUID search identified /usr/bin/find. The supplied GTFOBins evidence documents the SUID technique. Running the technique produced id output with uid=33(www-data) and euid=0(root), demonstrating successful privilege escalation.

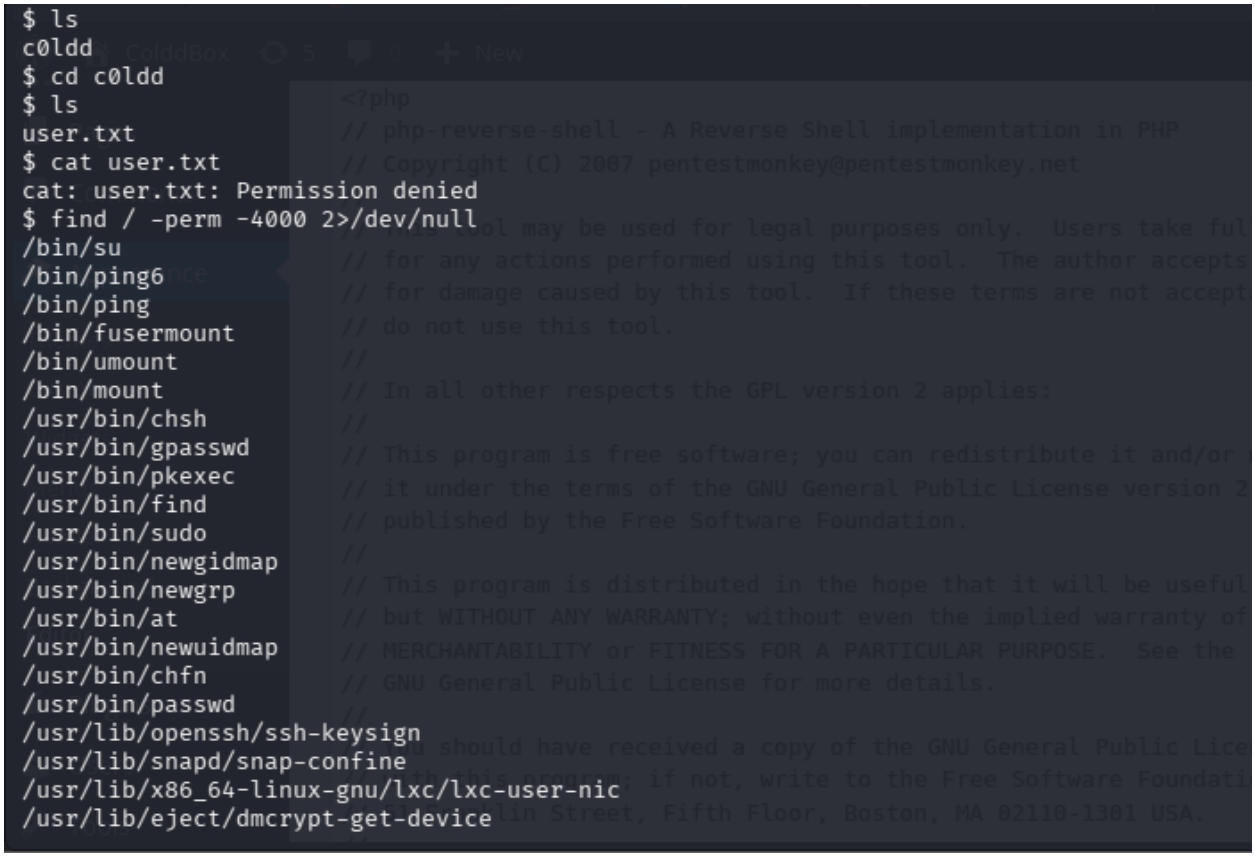


Figure 10. SUID-enabled binaries including /usr/bin/find.

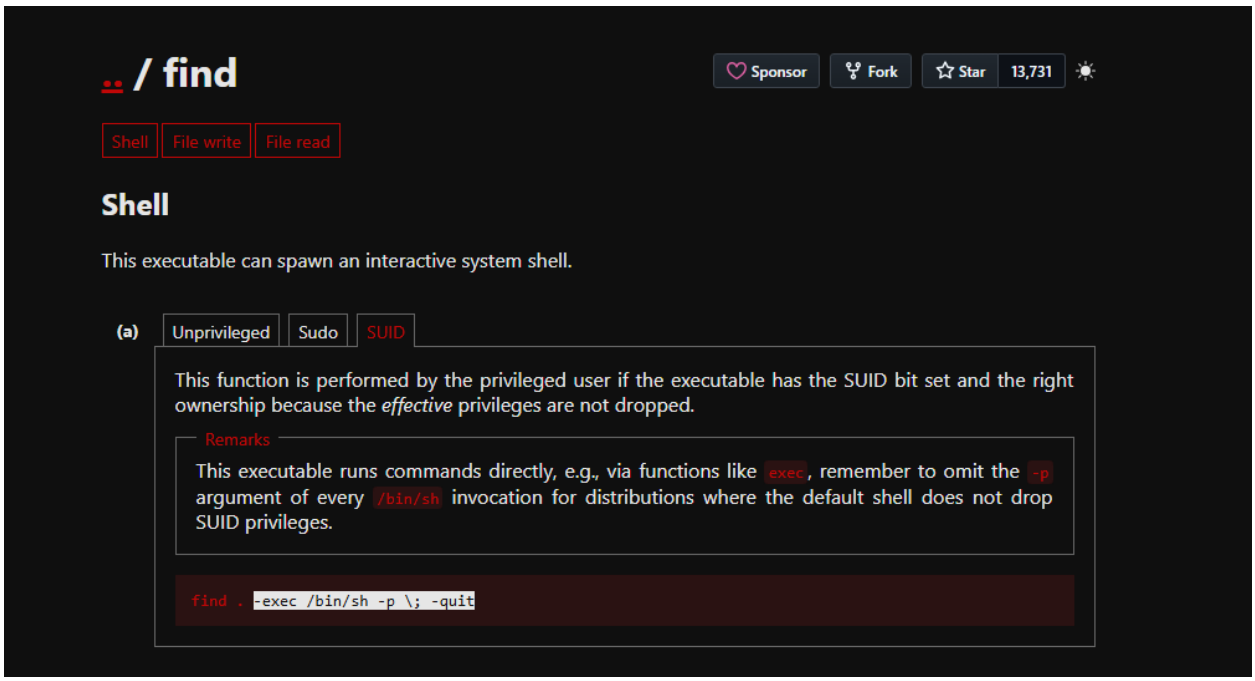


Figure 11. GTFOBins reference for the SUID find technique.

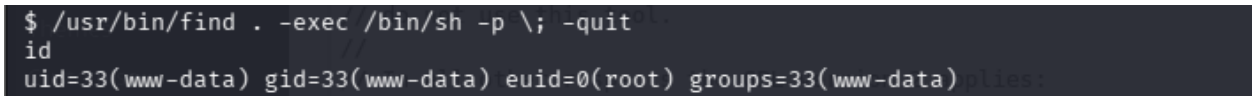


Figure 12. Privilege escalation result: euid=0(root).

3.7 Root-Level Objective Evidence

The session accessed /root and displayed root.txt. Flag values are intentionally not reproduced in this report.

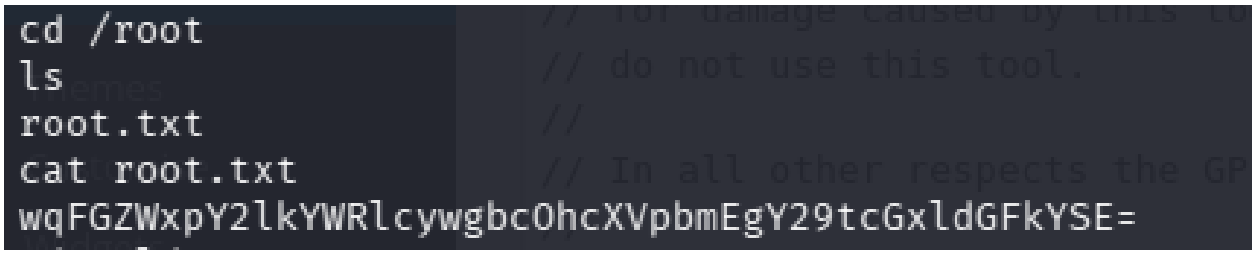


Figure 13. Access to /root and root.txt; flag omitted.

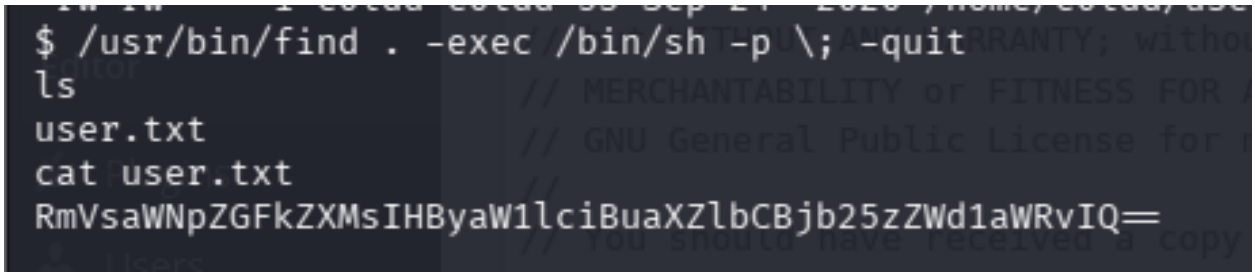


Figure 14. Additional command execution evidence; flag omitted.



Figure 15. whoami output from the supplied session.

4. Defensive Remediation & Hardening Plan

4.1 Authentication Hardening

• Enable MFA/2FA for every WordPress administrator.

• Require long, unique passwords and block common/known passwords.

• Apply rate limiting and progressive lockout to wp-login.php.

• Disable XML-RPC if it is not required.

• Alert on repeated failures followed by a successful login.

• Use WAF/reverse-proxy controls to limit automated authentication abuse.

4.2 Restrict WordPress Code Editing

The Theme Editor turned an authenticated WordPress session into arbitrary PHP execution. Disable web-based code editing and separate content administration from code deployment.

```
define('DISALLOW_FILE_EDIT', true);
```

• Deploy themes/plugins through a controlled release process.

• Keep WordPress core, themes and plugins patched.

• Remove unused themes and plugins.

• Restrict administrator privileges to the minimum required.

4.3 SUID / Privilege Escalation Hardening

• Audit SUID/SGID binaries and remove unnecessary elevated permissions.

• Do not grant web-service accounts broad sudo rights.

• Apply least privilege and isolate web applications from sensitive host resources.

• Use integrity monitoring for privileged binaries and critical WordPress files.

• Review sudoers NOPASSWD and broad command permissions.

4.4 Detection & Monitoring

• Detect repeated authentication failures followed by success.

• Alert on administrative theme/plugin file changes.

• Monitor Apache/PHP for unexpected shells or outbound connections.

• Alert on SUID binary execution by www-data.

• Centralize WordPress, Apache/PHP and Linux security logs.

4.5 Validation / Retest Plan

Retest the same controlled environment after remediation. Verify authentication rate limiting and alerting, confirm the Theme Editor is disabled, confirm unnecessary SUID paths no longer yield elevated privileges, verify www-data cannot access /root, and confirm security events are visible in centralized logging.

5. Conclusion

The evidence demonstrates a chained compromise: weak authentication enabled administrative WordPress access; administrative code editing enabled server-side command execution; and an unsafe SUID configuration enabled privilege escalation to effective root. Breaking any one of these links would substantially reduce the likelihood of full host compromise.

The recommended defense is layered: strengthen identity controls, remove web-based code execution paths, enforce operating-system least privilege, and monitor the events that connect these stages.

6. Appendix — Evidence Index

Figures	Evidence	Significance
1	ifconfig	Network context
2	Nmap	HTTP/Apache service discovery
3	Gobuster	WordPress/admin content discovery
4–5	WPScan	Credential attack and success
6–8	Theme Editor/source	PHP execution path
9	Netcat	www-data shell
10–12	SUID/find/id	Effective root privileges
13–15	/root/whoami	Objective and session evidence

Handling note: Passwords, flags, and other reusable secrets are intentionally not reproduced in the report body. Keep original screenshots and raw logs in a restricted evidence archive.